DETECTION-LAB · RAPPORT DE CAMPAGNE

Module 03 — Le réseau

Détecter un canal de commande depuis le fil : signatures, métadonnées et rythme

Suricata 8.0.7 · ET Open · Zeek 9.0.0 · balisement.py · pktmon · MITRE ATT&CK

Auteur	**Mamadou Lamine Thiore** — Master 2 Cybersécurité, EPSI Lyon, spécialisation Blue Team
Campagne	12 au 15 octobre 2026
Environnement	Sonde Ubuntu Server 26.04.1 isolée (réseau hôte uniquement), VMware Workstation Pro · VM Windows 11 du lab pour la référence normale
Données	3 captures d'infection publiques (Malware-Traffic-Analysis.net) · 1 capture de trafic normal
Dépôt	`github.com/jtthre/detection-lab` · dossier `03-reseau/` · commit `31689bc`
Livrable de référence	`matrice-couverture.md`

Sommaire

1. Synthèse
2. Contexte et objectif
3. Environnement de la sonde et garde-fous
4. Outillage
5. Méthode
6. Les données : quatre captures
7. Résultats : la matrice de couverture
8. Capture 1 — Lumma Stealer
9. Capture 2 — NetSupport Manager RAT
10. Capture 3 — RAT « CNCmachineRMS » (Natureforce)
11. La référence : trafic normal d'un poste Windows
12. Trois règles à soi
13. Ce que la campagne a changé dans les scripts
14. Incidents de campagne
15. Limites
16. Enseignements de méthode
17. Reste à faire
18. Annexes : A. Règles locales · B. Commandes de référence · C. Techniques ATT&CK · D. Glossaire

1. Synthèse

Les modules 01 et 02 ont construit et éprouvé une détection **sur le poste**. Le module 03 ajoute la seconde moitié de ce que regarde un SOC : **le trafic réseau**. La question posée : **un canal de commande et de contrôle (C2) est-il visible depuis le fil, par quel outil, et pourquoi pas par les autres ?**

Trois captures réelles d'infection, choisies pour leurs canaux différents, ont été passées aux mêmes outils : **Suricata** (signatures, jeu public ET Open), **Zeek** (métadonnées) et un script de **balisement** écrit pour le module (régularité des échanges). Une quatrième capture, du **trafic normal** d'un poste Windows sain, mesure les fausses alertes. Là où rien ne voyait le C2, une règle locale a été écrite, puis réglée sur le trafic normal.

3 / 3
canaux C2 identifiés, dont un seulement grâce à une règle écrite pour le module

1 / 30
alertes ET Open sur Lumma qui survivent à un changement de nom de domaine

11 / 11
tests conformes pour les trois règles locales (bancs synthétiques, captures, trafic normal)

69 → 0
fausses alertes de la règle 1000003 sur le trafic normal, en trois révisions mesurées

Capture	Canal C2	Suricata (ET Open)	Zeek / balisement	Verdict
Lumma Stealer 2026-01-31, 10 min	HTTP clair sur 80 + TLS sur 443	Vu 29 alertes sur 30 tiennent aux noms	Vu vol en clair ; 2,08 Mo en TLS ; balisement sans objet	Vu, fragile
NetSupport RAT 2026-02-28, 4 h 21	HTTP clair sur le port 443	Vu 264 rappels, sur le contenu	Vu balisement 1,0 sur les requêtes, invisible sur les connexions	Vu
RAT « CNCmachineRMS » 2026-10-01, 40 min	Protocole propre au RAT sur le port 443	Pas vu livraison vue, C2 non	Vu par anomalie 443 sans TLS, 37 min, 13,4 Mo reçus	Vu grâce à 1000003
Trafic normal 2026-10-14, 1 h 36	aucun	160 692 alertes, 99,9 % d'artefacts de capture, 0 malveillante	seules des paires internes au-dessus de 0,70	0 fausse alerte des règles locales

Ce que ce résultat dit

Les trois outils ne voient pas la même chose, et c'est le résultat. Les signatures sont précises mais tiennent souvent à un nom (Lumma) ; quand le C2 parle un protocole qu'aucune règle ne décrit (Natureforce), elles se taisent. Les métadonnées voient tout le déroulé mais ne jugent rien. Le balisement ne vaut que contre un implant qui rappelle, et seulement s'il est mesuré au bon niveau. La règle qui comble le trou décrit un **comportement** — « le port 443 sans TLS, pendant longtemps » — et n'a été publiable qu'après trois révisions réglées sur le trafic normal.

2. Contexte et objectif

Pourquoi le réseau

Un attaquant peut renommer un binaire, tuer un agent ou effacer un journal Windows. Il ne peut pas communiquer sans envoyer de paquets. Tout maliciel qui reçoit des ordres ou exfiltre des données traverse le réseau, et le réseau est observé par une machine qu'il ne contrôle pas : la sonde.

	Capteur poste (Sysmon, modules 01–02)	Capteur réseau (Suricata, Zeek, module 03)
Voit	processus, registre, fichiers, accès mémoire	connexions, protocoles, noms, certificats, volumes, rythmes
Ne voit pas	ce qui se passe sur le fil après l'envoi	ce qui se passe dans la machine
L'attaquant peut	désactiver l'agent, s'il a les droits	chiffrer, mais pas cacher *qu'il* communique
Couvre	les postes instrumentés	tout ce qui passe par le point de capture

Signature contre métadonnée

Une **signature** décrit un contenu précis : telle chaîne dans telle URI, tel motif d'octets, tel nom de domaine. Elle est précise et fragile — un octet changé, un chiffrement ajouté, et elle ne voit plus rien. Une **métadonnée** décrit la forme d'un échange : qui parle à qui, combien de fois, à quel rythme, avec quel volume. Elle ne dit pas « c'est malveillant », elle permet de remarquer ce qui ne ressemble pas au reste, au prix de faux positifs à mesurer.

C'est la leçon de la règle 09 du module 02 transposée au réseau : **reconnaître l'outil casse dès que l'outil change ; reconnaître le geste inévitable tient plus longtemps.** Un C2 peut changer de domaine, de chiffrement et de port ; il doit quand même parler à son serveur.

L'objectif, en une phrase par capture

- **Pour chaque capture d'infection** : le canal de commande documenté est-il visible, par quel outil, et pourquoi pas par les autres ?
- **Pour la capture de trafic normal** : combien de fausses alertes sur un poste sain, et chacune s'explique-t-elle ?
- **Là où aucun outil ne voit** : écrire une règle à partir d'un indicateur *observé*, prouver qu'elle déclenche, prouver qu'elle se tait sur le trafic normal, et dire ce qu'un attaquant devrait changer pour lui échapper.

> **Le critère d'échec qu'on oublie**
>
> Comme au module 02 : un outil qui alerte sur tout est aussi inutile qu'un outil muet. Le résultat sur le trafic normal compte autant que les détections sur les captures d'infection.

3. Environnement de la sonde et garde-fous

La sonde

Élément	Valeur
Système	Ubuntu Server **26.04.1 LTS** (noyau 7.0.0-38), VM VMware, 4 Go de RAM, 2 processeurs, disque LVM étendu à 28 Go
Suricata	**8.0.7** (paquet Ubuntu `1:8.0.7-0ubuntu3`), service désactivé : usage en mode fichier uniquement
Règles	ET Open via `suricata-update` : **53 133** règles actives, téléchargées le 13/10/2026 et figées pour toute la campagne
Zeek	**9.0.0** (LTS), paquets openSUSE Build Service pour xUbuntu 26.04, script `local`
Réseau	NAT pour l'installation et les téléchargements, puis **réseau hôte uniquement**. Adresse automatique + adresse fixe `192.168.234.10` (`/etc/netplan/60-sonde-ip-fixe.yaml`)
Droits	analyses lancées sans root ; l'utilisateur est membre du groupe `suricata` pour lire les règles

Le contrôle avant chaque analyse : `verifier-sonde.sh`

Huit contrôles, tous à « OK » avant d'ouvrir une capture : isolation (aucune route vers `1.1.1.1:443`), configuration Suricata valide, règles chargées (un Suricata sans règles n'alerte jamais et ne le signale pas), extraction de fichiers désactivée, Zeek et `zeek-cut` présents, outils annexes, aucun pcap dans le dépôt, au moins 5 Go libres.

Garde-fous

Règle	Pourquoi
Les captures ne vont **jamais** dans le dépôt (`*.pcap`, `*.pcapng`, `*.zip`, `*.etl` ignorés)	Trafic de maliciels réels, parfois les binaires eux-mêmes, reconstituables. On versionne la source, l'empreinte et les résultats.
Lecture `-r` uniquement, **aucune extraction de fichier**	L'exécutable de Natureforce a été identifié par son empreinte calculée par Zeek, jamais écrit sur disque.
Analyses dans la sonde isolée, non root	Un analyseur de protocoles est une surface d'attaque (Suricata 8.0.7 corrige 67 vulnérabilités).
Aucune visite des indicateurs	Les domaines et adresses des C2 sont notés désarmés (`[.]`) et jamais résolus ni visités.
Le trafic normal n'est **pas versionné**	Il contient la navigation de la VM. Seul un résumé public, écrit à la main, sans noms de domaine, est dans le dépôt.
Vérité terrain écrite **avant** l'analyse	On note ce qui doit être trouvé, puis on regarde les outils (`preuves/sources.md`).

Circuit des fichiers

Le dépôt vit sur l'hôte (`C:\Users\thior\detection-lab`) et dans la sonde (`~/detection-lab`). Les scripts passent de l'hôte à la sonde par `scp` ; les rapports reviennent par `scp -r` avant commit. La capture normale est allée **directement** de la VM Windows à la sonde (client OpenSSH de Windows 11, VM en réseau hôte uniquement), sans transiter par l'hôte, et son empreinte a été comparée des deux côtés.

4. Outillage

Suricata — le moteur de signatures

Moteur IDS/IPS open source de l'OISF. Il reconstitue les flux, identifie le protocole applicatif **quel que soit le port** (HTTP, TLS, DNS, SMB…), compare chaque flux à des dizaines de milliers de règles et écrit tout dans `eve.json` (une ligne JSON par événement : `alert`, `flow`, `http`, `tls`, `dns`, `fileinfo`…). En mode fichier, une capture rejouée donne le même résultat à chaque passage.

```
suricata -r capture.pcap -k none -l sortie/          # -k none : ne pas rejeter les sommes de
contrôle invalides
suricata -r capture.pcap -k none -S regles/local.rules -l /tmp/t   # -S : CES règles seulement
```

Deux champs de `eve.json` ont décidé de la campagne : `app_proto` (le protocole reconnu, ou `failed` quand aucun analyseur ne correspond) et `flow.age` (la durée du flux).

Zeek — le greffier du réseau

Zeek ne cherche pas de menace : il décrit. Une ligne par connexion, requête, fichier ou certificat, dans des journaux reliés par le champ `uid`.

Journal	Une ligne par…	Ce qu'il a apporté dans ce module
`conn.log`	connexion	Le C2 Natureforce : service `-`, 2 233 s, 13,4 Mo reçus. L'exfiltration Lumma : 2,08 Mo envoyés en TLS.
`http.log`	requête HTTP	Le vol Lumma en clair, les 264 rappels NetSupport, l'agent `curl` de Natureforce.
`dns.log`	requête DNS	La chronologie Lumma ; l'absence de toute résolution des C2 NetSupport et Natureforce.
`ssl.log` / `x509.log`	négociation TLS / certificat	Le SNI `whitepepper[.]su` ; l'absence de TLS sur le C2 Natureforce.
`files.log`	fichier transféré	Le SHA-256 de `runner_ilove.exe`, identique au compte rendu, **sans extraction**.
`pe.log`	exécutable Windows vu	PE 64 bits, non signé, date de compilation falsifiée (2059).

`balisement.py` — mesurer le rythme

Un implant qui rappelle son serveur le fait à intervalle et volume presque constants. Le script regroupe les événements par paire (source, destination, port) et note leur régularité de 0 à 1, avec des statistiques robustes (médiane, écart absolu médian, asymétrie de Bowley), la même famille de calcul que RITA.

```
régularité = 0,7 × (1 − min(1, MAD / médiane)) + 0,3 × (1 − |Bowley|)
score      = 0,45 × régularité des intervalles + 0,35 × régularité des volumes + 0,20 ×
persistance
lecture    : ≥ 0,85 très régulier · 0,70 à 0,85 régulier · en dessous, peu probant
```

Option	Rôle — et la capture qui l'a rendue nécessaire
entrée `conn.log` **ou** `http.log`	Mesurer les connexions ou les requêtes. NetSupport : une connexion de 4 h 20 qui porte 264 requêtes, invisible au niveau connexion, à 1,0 au niveau requête.
`--min-connexions 20`, `--duree-min 300`	En dessous, aucune statistique n'est fiable. Lumma : une paire Microsoft de 5 connexions en 74 s sortait à 0,78, au-dessus du vrai C2.
`--externes-seulement`	Écarte privé, multicast et diffusion. NetSupport et trafic normal : NetBIOS et mDNS sortaient à 1,0. Contrepartie : masque un C2 interne.
`--reference <conn.log normal>`	Marque une destination « inédite » si le trafic normal ne la contient pas. Le C2 NetSupport : 1,0 et inédite.

`analyser-pcap.sh` — la chaîne complète

Empreinte SHA-256, Suricata, Zeek, balisement sur `conn.log` et `http.log`, puis `resume.md` : alertes par signature, volumes Zeek, services, destinations, DNS, SNI, requêtes HTTP, notices, **connexions au port 443 sans TLS ni QUIC de plus d'une minute**, et une section Verdict à écrire à la main. Le script mesure ; il ne conclut pas.

`pktmon` — le capteur intégré à Windows

Disponible jusque sur l'édition Famille. `--comp nics` capture au seul niveau de la carte réseau (sans cette option, chaque paquet est compté plusieurs fois, ce qui fausserait le balisement) ; `pktmon etl2pcap` convertit le journal ETL en pcapng.

5. Méthode

1. **Vérité terrain d'abord.** Pour chaque capture : source, nom, taille, SHA-256 calculé dans la sonde et ce que dit le compte rendu, écrits dans `preuves/sources.md` *avant* toute analyse.
2. **La même capture aux trois outils.** `analyser-pcap.sh` produit les sorties de Suricata, de Zeek et du balisement dans un même dossier de rapport.
3. **Des questions précises** sur le C2 documenté : combien de connexions, quel protocole reconnu, quels volumes, quel rythme, quelle alerte.
4. **Un verdict par outil** : Vu (le C2 lui-même est identifié), Partiel (l'infection est vue, pas le canal), Pas vu. Chaque `resume.md` se termine par « Vu par Suricata / Vu par Zeek / Vu par personne ».
5. **La référence normale** mesure chaque fausse alerte et fixe les seuils.
6. **Une règle à soi**, en six étapes : l'écrire à partir d'un indicateur *observé* ; la tester seule (`-S`) sur un banc synthétique ; prouver qu'elle déclenche sur la capture ; prouver qu'elle se tait sur le trafic normal ; seulement ensuite l'ajouter au jeu de la sonde ; écrire ce qu'un attaquant devrait changer pour lui échapper.

> **Pourquoi des captures publiques**
>
> Rejouer de vrais maliciels n'est ni nécessaire ni souhaitable pour éprouver une détection réseau. Les exercices de Malware-Traffic-Analysis.net fournissent du trafic réel d'infection, un compte rendu qui sert de vérité terrain, et la même capture pour tout le monde : un résultat vérifiable par un tiers.

6. Les données : quatre captures

Étiquette	Taille · période	SHA-256	Vérité terrain
`lumma-2026-01-31`	27 242 609 o 10 min	`f755444d…b959d7833`	**Lumma Stealer**. Victime `10.1.21.58`, C2 `153.92.1[.]49`, domaine `whitepepper[.]su`.
`netsupport-2026-02-28`	6 581 991 o 4 h 21	`3dc470f5…a8ef407e61`	**NetSupport Manager RAT**. C2 `45.131.214[.]85`, TCP 443. Victime observée `10.2.28.88`.
`natureforce-2026-10-01`	36 838 132 o 40 min	`287d6dee…f8dbbc8274b`	**RAT « CNCmachineRMS »**. Victime `10.10.1.128` (`bdiaz`), exécutable `runner_ilove.exe` depuis `107.175.82[.]242:9000`, C2 publié `195.64.128[.]106:443`.
`normal-2026-10-14`	1 932 694 968 o 1 h 36	`cc2e1080…99f0b1b607`	Trafic normal de la VM Windows du lab, aucune campagne de test, Defender actif. Non versionné.

La vérité terrain se vérifie aussi

Compte rendu	Ce qu'il dit	Ce que montrent les journaux
Lumma	Victime `10.1.28.58` puis `10.1.21.58` ; C2 `153.92.1.49` puis `154.92.1.49`	Deux coquilles : `10.1.21.58` et `153.92.1.49`, confirmés par Zeek.
NetSupport	Domaine `easyas123[.]tech` parmi les indicateurs	C'est l'**Active Directory de la victime** (contrôleur `easyas123-dc` → `10.2.28.2`) : un nom interne, pas un indicateur.
Natureforce	C2 `195.64.128[.]106`	Aucune trace de cette adresse ; le C2 de la capture est **`195.63.128.106`**.

> **Une empreinte n'est pas une preuve si l'on n'a pas vérifié la taille**
>
> Une première extraction avec un mauvais mot de passe a laissé un fichier de 0 octet, dont le SHA-256 est `e3b0c442…b855` — l'empreinte bien connue d'un fichier vide. Depuis, la taille est contrôlée avant de reporter l'empreinte.

7. Résultats : la matrice de couverture

Capture	Canal C2	Suricata (ET Open)	Zeek / balisement	Verdict
Lumma	HTTP clair sur 80 (`/api/set_agent`) + TLS sur 443, même serveur	Vu 30 alertes Lumma, dont 29 sur des noms de domaine et 1 sur le comportement (URI)	Vu vol en clair dans `http.log` ; 2,08 Mo envoyés en TLS dans `conn.log` · balisement non applicable (rafale de 29 s)	Vu, fragile sans les noms, il reste une signature et un volume
NetSupport	HTTP clair sur le port 443	Vu 264 « Remote Admin Checkin », un par rappel, + « HTTP sur 443 »	Vu `http.log` (agent `NetSupport Manager/1.3`) · balisement : rien sur `conn.log`, **1,000** sur `http.log`	Vu à condition de mesurer les requêtes
Natureforce	Protocole propre au RAT sur 443, une connexion de 37 min	Partiel livraison vue (5 alertes), C2 non vu	Vu par anomalie service `-` sur 443, 13,4 Mo reçus ; SHA-256 de l'exécutable confirmé · balisement non applicable	Vu grâce à 1000003

Les règles écrites pour le module

SID	Indicateur	Sur la capture	Trafic normal	Pour lui échapper
1000001	`GET /api/set_agent?id=<32 hex>&token=…&agent=`	**2 / 2** (ET : 1)	**0**	renommer le chemin ou ses paramètres ; passer en HTTPS
1000002	`POST /api/set_agent?…&act=log`	**2 / 2** (ET : 0)	**0**	idem
1000003	Port 443, aucun protocole reconnu, flux de plus de 5 min	**1 / 1** (ET : 0)	**0** (rev 3)	parler un vrai TLS, changer de port, couper avant 5 min

Bilan détaillé des 11 tests : `preuves/bilan-regles-locales.xlsx`.

8. Capture 1 — Lumma Stealer

2026-01-27 23:04:03 → 23:14:25 UTC · victime `10.1.21.58` (DESKTOP-ES9F3ML) · C2 `153.92.1[.]49`

Suricata — vu, par les noms

55 alertes, dont 30 propres à Lumma. **29 tiennent à un nom de domaine** : 16 sur le SNI `whitepepper[.]su` (2066542), 10 sur sa résolution DNS (2066541), 3 sur un second domaine `whooptm[.]cyou` (2066850/2066851). Une seule décrit le comportement : *Lumma Stealer Victim Fingerprinting Activity* (2066606), sur l'URI `GET /api/set_agent?…&agent=Chrome` — et la même requête pour Edge, 8 s plus tard, ne la redéclenche pas. Les 20 alertes sur les domaines de premier niveau `.su` et `.cc` sont, elles aussi, des heuristiques de nom.

Zeek — vu, et davantage

`http.log` montre le vol en clair vers `153.92.1.49:80` : pour Chrome puis Edge, `GET /api/set_agent` puis `POST …&act=log` (8 023 et 7 975 octets envoyés). Les requêtes portent les en-têtes d'un vrai navigateur (agent Chrome / Edge 144, Referer, demande de `/favicon.ico`) : l'agent HTTP ne trahit rien. Surtout, `conn.log` montre que **l'essentiel part en TLS** : 2,08 Mo envoyés vers `153.92.1.49:443` en 18 connexions, contre 70 Ko reçus, entre 23:05:36 et 23:06:05. Le volet HTTP clair ne pèse que 19 Ko.

Balisement — non applicable

Un voleur d'informations frappe une fois et repart : toute l'activité vers le C2 tient en 29 s. Aucune paire n'atteint 20 événements sur 300 s. L'indice exploitable est le **rapport envoyé / reçu** — 30 pour 1 — vers une destination jamais vue.

Vu par personne

Le contenu des 2,08 Mo partis en TLS, et la nature des données volées (aucune extraction). L'infection initiale n'est pas dans la capture.

> **Constat**
> Un attaquant qui change de domaine fait tomber 29 alertes sur 30. Restent la signature sur l'URI et le volume sortant. C'est sur cette URI, observée dans `http.log`, que portent les règles locales 1000001 et 1000002 (§ 12).

9. Capture 2 — NetSupport Manager RAT

2026-02-28 19:55:06 → 2026-03-01 00:16:30 UTC · victime `10.2.28.88` (DESKTOP-TEYQ2NR) · C2 `45.131.214[.]85:443`

Suricata — vu, sur le contenu

264 × *ET REMOTE_ACCESS NetSupport Remote Admin Checkin* (2035892) : une alerte par rappel, exactement autant que de requêtes dans `http.log`. 264 × *ET INFO HTTP traffic on port 443 (POST)* (2013926) : générique, mais juste — du HTTP en clair sur le port du HTTPS (T1571). 2 × *Remote Admin Response* : les deux seules réponses du serveur.

Zeek — vu

`http.log` : 264 `POST /fakeurl.htm`, agent `NetSupport Manager/1.3`. Enregistrement à 19:55:51 (deux échanges : 22 → 69 octets, 244 → 153 octets), puis **260 rappels identiques de 36 octets, sans aucune réponse**. `conn.log` : une seule connexion de 15 637 s (4 h 20) porte le tout, capture complète (`missed_bytes` = 0). Aucune résolution DNS : l'implant joint le C2 par son adresse.

Balisement — pas vu, puis vu

Journal mesuré	Ce qui sort en tête	Lecture
`conn.log` (connexions)	NetBIOS interne, 1,0 toutes les 310 s	Le C2 n'est même pas évaluable : **une connexion ne fait pas une série**. En tête, du Windows normal.
`http.log` (requêtes)	`10.2.28.88 → 45.131.214.85:443`	Score **1,000** : 264 requêtes toutes les **60,1 s**, gigue 0 %, sur toute la capture. Face à la référence normale : **destination inédite**.

> **Constat**
> À l'inverse de Lumma, la détection ne dépend d'aucun nom : la signature lit le contenu du rappel et survit à un changement d'adresse. Mais un implant qui garde sa connexion ouverte efface son rythme de `conn.log` : le balisement doit se mesurer au niveau des requêtes — et cette mesure ne vaut que tant que le canal est en clair.

10. Capture 3 — RAT « CNCmachineRMS » (Natureforce)

2026-10-01 19:27:27 → 20:07:29 UTC · victime `10.10.1.128` (DESKTOP-4VGYQX7, `bdiaz`) · réseau Active Directory `natureforce.com`

Chronologie reconstituée

UTC	Événement	Vu par
19:28:30	La victime ouvre `www.ars-soar.com` (TLS). Rôle non établi par la capture.	Zeek
19:28:59	`curl/8.21.0` demande `holtandberyl.com/prw` puis `/crv`, redirigé vers HTTPS	Zeek seul
19:30:36	`curl` télécharge `http://107.175.82.242:9000/wilow/runner_ilove.exe` (1 646 592 o)	Suricata (5 alertes), Zeek
19:30:43	Résolution de `dns.google` en DNS classique	Zeek
19:30:44.127	Connexion **DNS over HTTPS** vers 8.8.4.4	Suricata (1 alerte INFO), Zeek
19:30:44.329	**Ouverture du C2** `195.63.128.106:443`, gardé 37 min	Zeek (anomalie), règle 1000003

La livraison — vue par tous

Cinq alertes ET sur le seul téléchargement : *PE EXE or DLL Windows file download HTTP* (gravité 1), *Executable Download from dotted-quad Host*, *curl User-Agent to Dotted Quad*, *Dotted Quad Host MZ Response* (gravité 2), *Packed Executable Download*. L'agent `curl` désigne une commande, pas un navigateur. Zeek calcule le SHA-256 du fichier — `b789adce…ad35061`, **identique au compte rendu** — sans qu'il ait été extrait, et `pe.log` le décrit : PE 64 bits, interface graphique, **non signé**, date de compilation **16/01/2059** (falsifiée).

Le C2 — vu par personne, sauf par anomalie

Mesure	Valeur	Lecture
Début	19:30:44 UTC	8 s après le téléchargement de l'exécutable
Durée	2 233 s (37 min)	une seule connexion, jusqu'à la fin de la capture ; 15 595 paquets
Protocole	Zeek `-` · Suricata `failed`	ni TLS, ni HTTP : le port 443 n'est qu'une façade (T1571, T1095)
Volumes	83 716 o envoyés · **13 382 927 o reçus**	la victime reçoit beaucoup : modules, charge ou ordres, impossible à trancher sans décoder
Alertes ET	1	*STREAM excessive retransmissions* — rien sur la nature du canal

Aucune résolution en clair du C2. La requête DNS over HTTPS 200 ms avant son ouverture est compatible avec une résolution chiffrée de son nom, **sans le prouver** : une adresse écrite en dur dans le binaire

donnerait la même absence.

Ce qui comble le trou

Le critère « port 443, ni TLS ni QUIC, plus d'une minute » donne **1** sur Natureforce, **1** sur NetSupport, **0** sur Lumma et **0** sur le trafic normal. Il figure désormais dans chaque `resume.md`, et la règle Suricata 1000003 en fait une alerte (§ 12).

> **Un même signal, deux intentions**
> *Dotted Quad Host MZ Response* (2021076) déclenche ici sur un vrai maliciel… et déclenchait sur le trafic normal pour une mise à jour de Defender servie par un cache Windows Update joint par adresse IP (§ 11). Même constat technique, intention opposée : une règle de chasse ouvre une piste, elle ne rend pas un verdict.

11. La référence : trafic normal d'un poste Windows

2026-10-14 10:00:24 → 11:36:27 UTC · 1 248 072 paquets · VM Windows du lab revenue à l'instantané « VM outillée hors ligne — module 02 », Defender actif

Capture

```
pktmon start --capture --comp nics --pkt-size 0 --file-name C:\Lab\normal.etl --file-size 2048
pktmon stop
pktmon etl2pcap C:\Lab\normal.etl --out C:\Lab\normal.pcapng
```

L'instantané datant du 01/10, la VM a rattrapé deux semaines de mises à jour : les 2 Go ont été remplis en **1 h 36**. Le dernier bloc du pcapng est tronqué (conversion interrompue, § 14) ; l'analyse ne perd que les derniers paquets.

Suricata — 160 692 alertes, aucune malveillante

Alertes	Signature	Explication
160 258	Sommes de contrôle IPv4 / TCP / UDP invalides	**Artefact de capture** : Windows délègue le calcul à la carte, `pktmon` voit les paquets sortants avant
200	IPv4 total length smaller than header size	**Artefact de capture** : découpage des gros envois délégué à la carte (LSO)
73	Applayer Wrong direction first data, retransmissions	Anomalies de flux ; les 69 premières sont des flux TLS dont Suricata a manqué le début (§ 12)
156	ET INFO Windows Update P2P Activity	Optimisation de livraison vers le port 7680 : 156 connexions, autant qu'au balisement
3	ET INFO Packed Executable Download	Mises à jour de Defender (`/msdownload/update/software/defu/…`)
1	ET HUNTING Dotted Quad Host MZ Response (gravité 2)	Mise à jour Defender servie par un cache Windows Update joint par IP (`85.208.10.203`)
1	ET INFO Microsoft Connection Test	Test de connectivité de Windows

Balisement sur trafic sain

- `conn.log` : quatre paires au-dessus de 0,70, toutes internes — NetBIOS vers la passerelle toutes les 120 s (1,0), optimisation de livraison vers l'hôte toutes les 40 s (0,867), mDNS IPv4 et IPv6 (0,72). Meilleure paire externe : **0,507**.
- `http.log` : une paire à **0,797** — 728 requêtes vers un cache Windows Update par morceaux de **262 144 octets exactement**, toutes les 1,5 s (gigue 42 %). C'est la taille constante des morceaux qui fait le score.
- **Seuil retenu : 0,85** sur `http.log` avec `--externes-seulement` — aucune paire normale ne l'atteint, le C2 NetSupport sort à 1,0.

> **Limite**
> 1 h 36 d'un poste qui rattrape ses mises à jour : c'est une référence de poste en maintenance, pas d'une journée de travail. Les seuils qui en découlent (0,85 pour le balisement, 5 min pour la règle 1000003) sont à recalibrer sur une capture de plusieurs heures.

12. Trois règles à soi

1000001 et 1000002 — l'URI du vol Lumma

Validées

Indicateur observé dans `http.log`, pas recopié du compte rendu · volontairement sans domaine, adresse ni port

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"LOCAL Lumma Stealer - enregistrement
d'un navigateur
  (GET /api/set_agent)"; flow:established,to_server; http.method; content:"GET"; http.uri;
  content:"/api/set_agent?id="; startswith; content:"&token="; distance:32; within:7;
  content:"&agent="; distance:0; pcre:"/^\/api\/set_agent\?id=[0-9A-F]{32}&token=[0-9a-
f]+&/";
  classtype:trojan-activity; sid:1000001; rev:1;)
```

Test	Attendu	Obtenu
Banc synthétique : 4 positifs (dont 2 vers un autre nom d'hôte), 4 négatifs	4 / 0	**4 / 0**
Capture Lumma (Chrome puis Edge, GET et POST)	4	**4** — ET Open : 1
Capture NetSupport (autre canal HTTP malveillant)	0	**0**
Trafic normal (1 248 072 paquets)	0	**0**

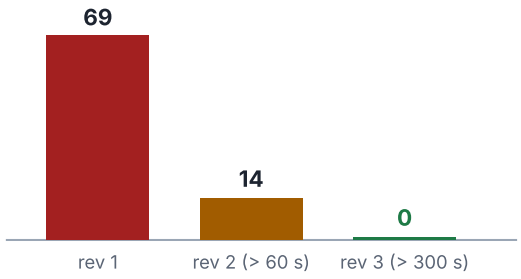
1000003 — le port 443 sans protocole reconnu

Validée (rev 3)

Comportement observé sur Natureforce · ne vise ni une famille, ni une adresse · une seule alerte par flux (flowbits)

```
alert tcp $HOME_NET any -> $EXTERNAL_NET 443 (msg:"LOCAL Port 443 sans protocole reconnu,
flux de plus
  de 5 minutes - canal sur mesure"; flow:established,to_server; app-layer-protocol:failed;
  flow.age:>300; flowbits:isnotset,local.port443_brut; flowbits:set,local.port443_brut;
  classtype:bad-unknown; sid:1000003; rev:3;)
```

Trois révisions, réglées sur la mesure



Fausses alertes sur le trafic normal, par révision. Sur Natureforce : 1 alerte à chaque révision.

rev 1, sans condition de durée : 69 fausses alertes. Le diagnostic les explique toutes : 69 des 70 flux 443 « failed » du trafic normal portent *Applayer Wrong direction first data*. Ce sont des sessions TLS légitimes dont Suricata n'a pas vu le premier message, écarté avec les paquets mal formés par la capture faite sur la machine elle-même.

rev 2 (plus de 60 s) : 14. Ces flux durent jusqu'à 185 s, médiane 7 s.

rev 3 (plus de 5 min) : 0, au-delà du plus long flux légitime observé, et le C2 Natureforce reste ouvert 37 min.

Test (rev 3)	Attendu	Obtenu
Banc synthétique : flux binaire de 10 min sur 443	1	**1**

Test (rev 3)	Attendu	Obtenu
Banc synthétique : HTTP clair sur 443, binaire sur 8443, binaire de moins d'1 s, binaire de 3 min	0	**0**
Natureforce	1	**1** — ET Open : 0
Lumma (TLS) · NetSupport (HTTP, couvert par ET 2013926) · trafic normal	0	**0**

Les bancs synthétiques (`regles/tests/generer-cas-lumma.py`, `generer-cas-port443.py`) fabriquent des flux à la main, entre adresses de documentation : aucun trafic réel. Ils documentent ce que chaque règle doit voir et ignorer, et se rejouent à chaque modification.

13. Ce que la campagne a changé dans les scripts

Changement	Capture qui l'a imposé	Pourquoi
`balisement.py` : `--duree-min 300`	Lumma	Cinq connexions en 74 s paraissaient « régulières » (0,78) sans rien dire d'un rythme.
`balisement.py` : lecture de `http.log`	NetSupport	Un implant qui garde une connexion ouverte n'a de rythme qu'au niveau des requêtes.
`balisement.py` : `--externes-seulement`	NetSupport, trafic normal	NetBIOS, mDNS et le contrôleur de domaine occupaient le haut du classement.
`analyser-pcap.sh` : `balisement-http.md`	NetSupport	Les deux niveaux de mesure dans chaque rapport.
`analyser-pcap.sh` : section « Port 443 sans TLS ni QUIC »	Natureforce	L'anomalie qui trahit le C2 doit sauter aux yeux dans le rapport.
`.gitignore` : rapports normaux	Trafic normal	Seul `resume-public.md` peut être versionné.

14. Incidents de campagne

Ce qui n'a pas marché du premier coup, et ce qu'on en garde.

Incident	Cause	Correction / leçon
Deux écrans bleus **0x124** (`WHEA_UNCORRECTABLE_ERROR`) pendant `pktmon etl2pcap`	Disque de l'hôte plein : **1,2 Go libres** sur ~510 Go ; aucune erreur WHEA sur l'hôte lui-même	Ménage (cache pip, ISO, données Docker) jusqu'à 35 Go libres. On vérifie la place sur l'hôte avant une conversion qui écrit autant qu'elle lit.
pcapng normal tronqué en fin de fichier	Conversion interrompue par l'écran bleu	Suricata lit 1,73 Go de paquets avant le bloc final : référence conservée, limite notée.
Référence de 1 h 36 seulement	Fichier circulaire de 2 Go rempli par les mises à jour	Prochaine capture : VM déjà à jour, `--file-size 8192`.
Carte `ens33` désactivée après passage en réseau hôte uniquement	Comportement d'Ubuntu au changement de réseau virtuel	`sudo ip link set ens33 up && sudo netplan apply` depuis la console VMware.
Adresse de la sonde passée de `.129` à `.130`	Adresse automatique du réseau hôte uniquement	Adresse fixe `192.168.234.10` ajoutée, hors de la plage distribuée ; empreinte SSH vérifiée.
Fichier de 0 octet après extraction	Mauvais mot de passe d'archive	Contrôle de la taille avant de reporter une empreinte.
Logiciel de messagerie (Courier) en écoute après l'installation de Zeek	Dépendance tirée par `zeekctl`	Services désactivés, ports vérifiés avec `ss -tlnp`.

15. Limites

- **Trois captures d'infection** : assez pour montrer trois manières de voir et de ne pas voir, pas pour mesurer un taux de détection.
- **Aucun C2 en vrai TLS dans le lot.** Les deux C2 sur 443 ne parlent pas TLS. Le cas où seuls le certificat, l'empreinte TLS et le rythme restent n'a pas été éprouvé.
- **Une référence courte et atypique** : 1 h 36 d'un poste qui se met à jour. Les seuils (0,85, 5 min) en dépendent.
- **Une capture faite sur la machine** : sommes de contrôle et longueurs faussées. Un TAP ou un port miroir donnerait une référence plus propre — et la règle 1000003 rev 1 aurait sans doute produit moins de fausses alertes.
- **ET Open figé au 13/10/2026** : les résultats Suricata valent pour cette version du jeu, pas pour celle du jour.
- **Pas de décodage des protocoles propriétaires** : on sait que 13,4 Mo ont été reçus par le C2 Natureforce, pas ce qu'ils contiennent.
- **Hypothèses non prouvées** : la résolution du C2 Natureforce par DNS over HTTPS ; le rôle de `www.ars-soar.com`.

16. Enseignements de méthode

1. **Mesurer au bon niveau.** Connexion ou requête : le même C2 passe de « non évaluable » à 1,000 selon le journal choisi.
2. **Une alerte qui nomme un domaine ne prouve pas qu'on détecte le maliciel.** 29 des 30 alertes Lumma tombent avec un changement de nom ; la signature NetSupport, qui lit le contenu, survit à un changement d'adresse.
3. **Le réseau interne Windows est régulier par nature.** NetBIOS, mDNS et le contrôleur de domaine occupent le haut du balisement.
4. **Un voleur ne balise pas.** Contre une rafale de 30 s, ce sont les signatures, `http.log` et le volume sortant qui répondent.
5. **Recouper le compte rendu avec les journaux.** Trois comptes rendus sur trois contenaient une erreur ou une ambiguïté.
6. **Capturer sur la machine elle-même fausse le paquet.** 99,9 % des alertes du trafic normal en viennent.
7. **Une règle de chasse est une piste, pas un verdict.** La même signature a raison sur Natureforce et tort sur une mise à jour de Defender.
8. **Une référence se dimensionne**, et l'hôte doit avoir la place de la produire.
9. **Le port ne dit pas le protocole.** Deux des trois C2 utilisent le port 443 sans TLS ; le vérifier est une détection simple, sans signature.
10. **Un C2 qui ne balise pas, ne résout pas en clair et ne parle pas un protocole connu** ne laisse qu'une trace : une connexion longue, au mauvais protocole, qui reçoit beaucoup. Les métadonnées la voient, les signatures non.
11. **Une règle de comportement se règle sur le trafic normal, pas sur l'attaque.** La première version de 1000003 voyait le C2… et 69 connexions saines. Sans référence normale, on aurait publié la première.

17. Reste à faire

Action	Pourquoi
Refaire la référence normale sur plusieurs heures, VM à jour, `--file-size 8192`	Recalibrer le seuil de balisement (0,85) et la durée de la règle 1000003 (5 min)
Une capture avec un C2 en vrai TLS	Éprouver ce qui reste quand on ne lit plus le contenu : certificat (`x509.log`), empreinte TLS, rythme
Une règle sur l'agent `curl` vers une adresse ou un domaine inconnu	L'étape 1 de Natureforce n'a déclenché aucune signature ; à mesurer d'abord sur le trafic normal
Ajouter les règles locales au jeu de la sonde (`suricata-update --local`)	Étape 5 de la méthode, une fois les seuils recalibrés
Module 04 : convergence dans un SIEM	Croiser la vue poste (Sysmon, Sigma) et la vue réseau (Suricata, Zeek) sur la même chronologie

Annexe A — Règles locales

Fichier complet, avec l'historique de chaque règle : `03-reseau/regles/local.rules`. SID 1 000 000 et plus, plage réservée à l'usage local.

```
alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"LOCAL Lumma Stealer - enregistrement d'un
navigateur (GET /api/set_agent)";
  flow:established,to_server; http.method; content:"GET"; http.uri; content:"/api/set_agent?
id="; startswith;
  content:"&token="; distance:32; within:7; content:"&agent="; distance:0;
  pcre:"/^\/api\/set_agent\?id=[0-9A-F]{32}&token=[0-9a-f]+&/"; classtype:trojan-activity;
sid:1000001; rev:1;)

alert http $HOME_NET any -> $EXTERNAL_NET any (msg:"LOCAL Lumma Stealer - envoi des donnees d'un
navigateur (POST /api/set_agent act=log)";
  flow:established,to_server; http.method; content:"POST"; http.uri; content:"/api/set_agent?
id="; startswith;
  content:"&agent="; distance:0; content:"&act=log"; distance:0; classtype:trojan-activity;
sid:1000002; rev:1;)

alert tcp $HOME_NET any -> $EXTERNAL_NET 443 (msg:"LOCAL Port 443 sans protocole reconnu, flux
de plus de 5 minutes - canal sur mesure";
  flow:established,to_server; app-layer-protocol:failed; flow.age:>300;
  flowbits:isnotset,local.port443_brut; flowbits:set,local.port443_brut; classtype:bad-unknown;
sid:1000003; rev:3;)
```

Annexe B — Commandes de référence

```
# Avant toute analyse
./scripts/verifier-sonde.sh

# Analyse complète d'une capture
./scripts/analyser-pcap.sh ~/pcaps/<capture>.pcap <etiquette>

# Tester les règles locales seules
suricata -r ~/pcaps/<capture> -k none -S regles/local.rules -l /tmp/t ; cat /tmp/t/fast.log

# Balisement au niveau des requêtes, face à la référence normale
python3 scripts/balisement.py <rapport>/zeek/http.log --externes-seulement --reference
<normal>/zeek/conn.log

# Le port 443 sans TLS ni QUIC, plus d'une minute
zeek-cut id.resp_p service duration < conn.log | awk '$1==443 && $2!~/ssl|quic/ && $3>60'

# L'empreinte d'un exécutable vu passer, sans l'extraire
zeek-cut ts mime_type filename total_bytes sha256 < files.log | grep -i dosexec
```

Annexe C — Techniques ATT&CK observées

Technique	Nom	Où
T1071.001	Protocole de couche application : Web	Lumma (HTTP vers `/api/set_agent`), NetSupport (HTTP)
T1571	Port non standard	NetSupport (HTTP sur 443), Natureforce (protocole propre sur 443), livraison sur le port 9000
T1095	Protocole hors couche application	Natureforce : protocole propre au RAT
T1573	Canal chiffré	Lumma : 2,08 Mo envoyés en TLS
T1041	Exfiltration par le canal C2	Lumma : données de navigateur
T1105	Transfert d'outils	Natureforce : `runner_ilove.exe` téléchargé par `curl`

Annexe D — Glossaire

C2	Command and Control : le canal par lequel un maliciel reçoit ses ordres et renvoie ses données.
Balisement	Rappels réguliers d'un implant vers son serveur (*beaconing*).
ET Open	Jeu public de règles Suricata d'Emerging Threats.
SNI	Nom du serveur envoyé en clair au début d'une session TLS.
DoH	DNS over HTTPS : résolution de noms chiffrée dans une session HTTPS.
LSO	Large Send Offload : découpage des gros envois confié à la carte réseau.
MAD	Écart absolu médian : mesure de dispersion qui résiste aux valeurs aberrantes.
Vérité terrain	Ce qui s'est réellement passé, d'après le compte rendu publié — à vérifier comme le reste.
pcap / pcapng	Formats de fichier de capture réseau.
flowbits	Marqueurs Suricata posés sur un flux, ici pour n'alerter qu'une fois par flux.